

Aula 2 (Módulo 04) — Wireshark, Zeek, Suricata e NetFlow

1. Duas formas de olhar para o tráfego de rede

Existem, no fundo, duas abordagens complementares para observar tráfego: **captura completa de pacotes** (ver o conteúdo exato do que passou) e **metadados de fluxo** (só um resumo — quem falou com quem, quanto, quando — sem o conteúdo). Cada ferramenta desta aula se encaixa em uma dessas abordagens (ou nas duas).

2. Wireshark — inspeção manual, pacote a pacote

Wireshark é a ferramenta gráfica mais conhecida do mundo para capturar e analisar tráfego de rede em detalhe. Ele mostra **cada pacote**, decodificado camada por camada — exatamente a pilha que estudamos no Módulo 03: Ethernet (MAC) → IP → TCP/UDP (porta) → protocolo de aplicação (HTTP, DNS...).

```
Camada 2 (Ethernet) → endereços MAC de origem/destino
Camada 3 (IP)       → endereços IP de origem/destino
Camada 4 (TCP/UDP) → portas, flags (SYN/ACK/FIN...)
Camada 7 (aplicação) → conteúdo HTTP, consulta DNS, etc. (se não estiver
                    criptografado por TLS)
```

Filtros — a habilidade mais importante do Wireshark

Sem filtro, uma captura de rede tem volume demais para analisar manualmente. Filtros de exibição (*display filters*) são essenciais:

```
ip.addr == 192.168.1.10      # só pacotes de/para esse IP
tcp.port == 443              # só tráfego na porta 443
http.request                 # só requisições HTTP
dns.qry.name contains "exemplo" # só consultas DNS contendo esse texto
tcp.flags.syn == 1 && tcp.flags.ack == 0 # só pacotes SYN (início de conexão)
```

Por que importa para segurança: Wireshark é a ferramenta certa quando você precisa **entender profundamente um caso específico** — por exemplo, examinar exatamente o conteúdo de uma conexão suspeita já identificada por outra ferramenta. Não é, geralmente, a ferramenta para monitorar tráfego continuamente em um ambiente grande (isso é papel do Zeek/Suricata, a seguir) — é mais como usar uma lupa depois de já saber onde olhar.

3. Zeek — geração de logs ricos de rede

Zeek (antigo nome: Bro) não é um IDS no sentido tradicional de "gerar um alerta de ataque conhecido" — ele é, antes de tudo, um **gerador de logs estruturados** sobre tudo que passa pela rede: uma linha de log para cada conexão (`conn.log`), uma para cada requisição HTTP (`http.log`), uma para cada consulta DNS (`dns.log`), uma para cada certificado TLS visto (`ssl.log`), e assim por diante.

Por que importa para segurança: essa abordagem é poderosíssima para **Threat Hunting** (Módulo 14) — em vez de depender só de alertas prontos, um analista consegue **consultar** esses logs estruturados livremente, com as mesmas perguntas que já treinamos: "quais domínios incomuns foram consultados essa semana?" (Módulo 03, Aula 4), "houve handshakes TCP incompletos em massa?" (Módulo 03, Aula 3, SYN flood), "algum certificado TLS suspeito, autoassinado, foi visto?" (Módulo 03, Aula 7). Esses logs, enviados a um SIEM (Módulo 09), formam uma das bases de dados mais valiosas para qualquer investigação de rede.

4. Suricata — detecção baseada em regras, em tempo real

Suricata é um NIDS/NIPS (Aula 1) de alta performance, que analisa tráfego **em tempo real** contra um conjunto de **regras/assinaturas** (lembra da detecção por assinatura da aula anterior?) e gera **alertas** quando encontra correspondência. Também consegue rodar em modo IPS, bloqueando ativamente.

Uma regra Suricata simplificada se parece com:

```
alert tcp any any -> any 22 (msg:"Possível brute force SSH"; flow:to_server; threshold:type both, track by
```

Traduzindo: "gere um alerta se detectar 5 ou mais tentativas de conexão TCP para a porta 22, vindas do mesmo IP de origem, em 60 segundos" — literalmente a mesma lógica de detecção de brute force SSH que já construímos manualmente com `grep` / `awk` no Módulo 01! A diferença é que aqui isso roda automaticamente, em tempo real, sobre todo o tráfego da rede.

Conjuntos de regras públicas amplamente usados incluem o **Emerging Threats** (ET Open), mantidos e atualizados pela comunidade/fabricantes de segurança.

5. NetFlow — só o resumo, sem o conteúdo

NetFlow (tecnologia originalmente da Cisco; existem variantes como **sFlow**, **IPFIX**) registra **metadados de fluxo** — quem falou com quem, em qual porta/protocolo, quantos bytes/pacotes, por quanto tempo — **sem guardar o conteúdo** dos pacotes.

Origem	Destino	Porta	Protocolo	Bytes	Duração
192.168.1.10	140.82.112.3	443	TCP	45.230	12s

Por que importa para segurança: NetFlow é muito mais leve para armazenar do que captura completa de pacotes (viável para reter meses de histórico, mesmo em redes grandes), e é excelente para responder perguntas de **volume e padrão** — por exemplo, identificar **exfiltração de dados**: uma máquina enviando um volume de bytes muito acima do normal para um destino externo é um padrão clássico visível em NetFlow, mesmo sem nunca ter acesso ao conteúdo real transferido (que poderia estar criptografado de qualquer forma).

6. Conectando as quatro ferramentas

Wireshark → inspeção manual, pacote a pacote, profunda mas pontual
Zeek → logs estruturados de TODAS as conexões, ótimo para hunting
Suricata → alertas em tempo real via regras/assinaturas, pode bloquear (IPS)
NetFlow → metadados de volume/padrão, leve, retenção longa,
ótimo para detectar exfiltração

Um ambiente maduro normalmente usa várias dessas camadas juntas, alimentando um SIEM central — nenhuma sozinha responde a todas as perguntas.

7. Exercício prático

Se você tiver o Wireshark instalado (ou quiser instalar em um ambiente de laboratório isolado — nunca capture tráfego de uma rede sem autorização), capture alguns segundos de navegação normal e aplique o filtro:

```
http.request or tls.handshake.type == 1
```

Isso mostra as requisições HTTP não criptografadas e os handshakes TLS (início de conexão HTTPS) — uma boa forma de visualizar, na prática, a cadeia DNS → TCP → TLS que vimos no Módulo 03, Aula 7.

8. Recapitulando

- Wireshark: inspeção manual profunda, pacote a pacote — use quando já souber onde olhar.
- Zeek: logs estruturados por tipo de conexão — base rica para Threat Hunting.
- Suricata: alertas em tempo real via regras (como as consultas de brute force que já fizemos manualmente no Módulo 01) — pode bloquear em modo IPS.
- NetFlow: metadados leves de volume/padrão — chave para detectar exfiltração de dados sem precisar guardar conteúdo completo.

Próxima aula (fecha o Módulo 04)

Análise de PCAP — exercícios práticos guiados, aplicando tudo que aprendemos neste módulo e no Módulo 03 para responder perguntas reais sobre uma captura de tráfego.

Fontes recomendadas

- **Wireshark — documentação oficial (User's Guide)**: referência completa de filtros e uso. https://www.wireshark.org/docs/wsug_html_chunked/
- **Zeek — documentação oficial**: referência completa dos tipos de log gerados. <https://docs.zeek.org/en/current/>
- **Suricata — documentação oficial**: referência completa de sintaxe de regras. <https://docs.suricata.io/en/latest/>
- **Cisco — "NetFlow Overview" e RFC 7011 (IPFIX)**: referência técnica de NetFlow/IPFIX. <https://www.rfc-editor.org/rfc/rfc7011>

